Check-list sécurité et RGPD

À passer avant chaque nouvel outil IA et chaque nouvelle automatisation.

1 Les 5 réflexes RGPD

1 · Minimiser
ne fais circuler que les données nécessaires

2 · Anonymiser
« Client A » plutôt qu'un nom, sans numéros

3 · Outils sérieux
offre pro, hébergement connu, contrat de traitement (DPA)

4 · Limiter les accès
le strict nécessaire, double authentification

5 · Garder une trace
un registre : quel outil, quelles données, pourquoi

2 Ce qu'on ne colle jamais dans une IA grand public

- [ ] Données de santé, bancaires ou d'identité (n° de sécurité sociale, IBAN, pièce d'identité)
- [ ] Mots de passe, clés d'accès, codes
- [ ] Informations confidentielles sur un client sans son accord (contrat, litige, chiffres)
- [ ] Données de mes salariés (salaires, évaluations, arrêts maladie)

3 Mes réglages (à faire une fois)

- [ ] L'utilisation de mes conversations pour l'entraînement est désactivée dans mon assistant IA
- [ ] La double authentification est activée sur mon assistant, ma messagerie et ma plateforme d'automatisation
- [ ] J'utilise une offre professionnelle dès que l'IA touche aux données de mes clients

4 La check-list de toute automatisation

- [ ] Je sais quelles données circulent, et elles sont toutes nécessaires
- [ ] Les outils utilisés sont fiables et je connais leurs réglages de confidentialité
- [ ] Les comptes sont protégés par la double authentification
- [ ] Ce qui engage l'entreprise passe par une validation humaine
- [ ] Je serai prévenu·e si l'automatisation tombe en panne (notification d'erreur)
- [ ] L'automatisation est notée dans mon registre

5 Le registre de mes outils

Outil	Données traitées	Pourquoi	Entraînement désactivé ?	Double auth. ?

AI Act : pour l'administratif courant, sois transparent (indique quand un contenu réaliste est généré par IA, quand un client parle à un assistant) et garde un humain dans la boucle pour les décisions.